

GOV-011 Compliance Audit Report

Policy: Only Facts Can Answer a User Question

Auditor: Claude Opus 4.6 | Date: April 3, 2026 | Branch: dev

Copyright 2026 Skip Snow. All rights reserved.

1. Introduction

This report documents a compliance audit of the ChatHealthy.ai codebase against GOV-011. The policy states: User natural utterances allow AI to ask questions. Only facts found in ChatHealthy.ai data and the user context can give an answer. Statement 1 requires: User must be allowed to disambiguate any system inference.

The audit identified 12 violations: 2 CRITICAL, 4 HIGH, 5 MEDIUM, 1 LOW. Seven compliant patterns were also documented.

2. Violations

V001 [HIGH]: System prompt identifies AI as a person, not a translator

RULE 0 frames AI as acting as Skip Snow rather than a navigation assistant. Identity framing invites persona-based answering.

V002 [HIGH]: AI can freely paraphrase tool results

RULE 1 says answer only from tools but AI can editorialize. Unconstrained paraphrasing means AI choices shape the answer.

V003 [CRITICAL]: No server-side enforcement that AI uses tools

RULE 2 is prompt-only. No server-side check detects tool-less responses. LLM can ignore the rule and confabulate.

V004 [HIGH]: Final response is unvalidated LLM output

Chat loop returns LLM text with only URL sanitization. No gate verifies grounding in tool results.

V005 [MEDIUM]: Search term extraction without disambiguation

GPT-4.1-mini extracts search term without user confirmation. Misinterpretation proceeds uncorrected.

V006 [MEDIUM]: AI query expansion from training data

Haiku generates keyword stems from training data, not NUCC taxonomy. AI-invented terms drive database queries.

V007 [MEDIUM]: Specialty resolution returns 70 codes without disambiguation

All codes sent to query silently. User never confirms which specialties were selected.

V008 [LOW]: LLM edits LLM output for de-duplication

One AI decides what another AI output the user sees. Deterministic approach would keep system in control.

V009 [HIGH]: Research site guidance is hardcoded editorial

Guidance strings are developer opinions, not data-layer content. Outputs must trace to data layer.

V010 [MEDIUM]: URLGuardian uses AI for factual URL decisions

Haiku decides page relevance. AI making factual determination. Deterministic HTTP check is sufficient.

V011 [MEDIUM]: URLGuardian AI selects replacement URLs

AI picks replacement URL from search results. System should present candidates for user to choose.

V012 [LOW]: Follow-up question phrasing is AI-composed

AI composes travel follow-up question. Should be system-authored template.

3. Compliant Patterns

- * ToolRouter allowlist enforcement (GOV-004)
- * Provider search returns only MongoDB records
- * Clinical trials sourced from ClinicalTrials.gov API
- * Pagination deterministic after first page via /search
- * System summary_message built from structured data
- * Unknown question templates system-authored, presented verbatim
- * Pydantic validation constrains tool inputs

4. Conclusion

The most significant gap is the absence of server-side enforcement that LLM responses are grounded in tool results (V003, V004). The system has strong data-layer patterns for provider search, clinical trials, and pagination. But the final LLM-to-user text path has no validation gate.

Secondary concerns: AI-driven URL decisions (V010, V011), missing user disambiguation on specialty resolution (V005, V007), and LLM-generated query expansion from training data (V006).

Recommendations:

1. Add server-side grounding gate: block LLM responses that reference no tool call.
2. Require user disambiguation when specialty resolution returns more than 5 codes.
3. Move all editorial content to brain artifacts.
4. Replace LLM query expansion with taxonomy-driven synonym lookup.
5. Replace LLM de-duplication with deterministic template rendering.